

****NEWSLETTER N. 521 of April 10, 2024****

****Hacker Attack on the IT Systems of the Lazio Region: Privacy Authority Sanctions****

****Health Dossier: The Privacy Authority Sanctions an ASL****

****Pa: Website Transparency, the Privacy Authority Requests More Protections for Personal Data****

****EU Prosecutor's Interceptions: Privacy Authority Approves National Database****

****Hacker Attack on the IT Systems of the Lazio Region: Privacy Authority Sanctions****

With three fines of €271,000, €120,000, and €10,000, imposed respectively on LAZIOcrea (the company managing regional information systems), the Lazio Region, and ASL Roma 3, the Privacy Authority has concluded the proceedings opened following the cyber attack on the regional health system that occurred on the night of July 31 to August 1, 2021. The data breach—caused by ransomware introduced into the system via a laptop used by a regional employee—blocked access to many health services, preventing, among other things, the management of appointments, payments, retrieval of medical reports, and registration of vaccinations. ASLs, hospitals, and nursing homes were unable to use certain regional information systems, through which health data of millions of patients are processed, for a period ranging from a few hours (48) to several months. [SEE PROVISIONS doc. web n. 10002324, 10002533, 10002287]

From the investigations and inspections carried out by the Authority, it emerged that LAZIOcrea and the Lazio Region, despite having different roles and levels of responsibility, committed numerous and serious violations of privacy regulations, primarily due to the adoption of outdated systems and the failure to implement adequate security measures to promptly detect personal data breaches and ensure the security of IT networks. The inadequate security of the systems resulted, during the cyber attack, in the inability of regional health facilities to access the system and provide certain health services to their patients. In particular, the unavailability of data was caused by the cyber attack, which rendered approximately 180 virtual servers inaccessible, as well as by LAZIOcrea's decision to shut down all systems, being unable to determine which ones were compromised or to prevent further propagation of the malware. Furthermore, LAZIOcrea did not take the necessary actions for the proper management of the data breach and its consequences, particularly concerning the subjects for whom it acts as data processor (starting from the numerous health facilities involved). The Lazio Region, for its part, as the data controller, should have exercised more effective oversight over LAZIOcrea, as its data processor, ensuring a level of security appropriate to the risks as well as the protection of data from the design stage. In determining the amount of the fines, the Authority took into account the nature and severity of the violations, as well as the degree of responsibility, particularly of entities such as LAZIOcrea and the Lazio Region. To ASL Roma 3, which, unlike other health facilities, did not report the data breach caused by the unavailability of health data of the patients processed within certain systems, the Authority applied a fine of €10,000.

****Health Dossier: The Privacy Authority Sanctions an ASL****

The Privacy Authority has fined an ASL €75,000 for failing to correctly configure the access methods to the electronic health dossier (Dse). The Authority acted following several complaints and reports that alleged the unlawful processing of personal data carried out through the archiving and reporting system of the services provided by the health company. In particular, repeated accesses to the Dse by healthcare personnel not involved in the patient care process were reported. In one case, a professional from the ASL was able to view the laboratory tests of her ex-husband without his knowledge, even though he was not under her care.

From the checks carried out by the Authority, it emerged that the Dse management system allowed healthcare operators to manually enter, through self-certification, the reason for which access to the health dossier was necessary. Access to the document was also allowed, by default, to a wide list of professional figures who had nothing to do with the patients' care process, including administrative staff.

All of this violated what was established by the Privacy Authority with the "Guidelines on Health Dossier" of June 2015, in which the Authority stated that "the data controller must pay particular attention in identifying the authorization profiles, adopting technical authentication methods to the dossier that reflect the access scenarios."

****proprie di ciascuna struttura**** guaranteeing that access to the dossier is limited to only the healthcare personnel involved over time in the patient's care process. The Privacy Authority has finally ascertained further unlawful acts, including the failure to implement an alert system aimed at identifying anomalous or risky behaviors related to the operations performed by those responsible for processing (e.g., regarding the number of accesses made, the type or the time frame of the same). In addition to applying the administrative sanction, the Authority has therefore ordered the ASL to implement all necessary technical and organizational measures to ensure the security of the personal data processed and to prevent new unauthorized accesses.

****Pa: transparency sites, the Privacy Authority requests more protections for personal data****

Favorable opinion of the Privacy Authority to Anac on 14 out of fourteen standard publication schemes that set the rules that public administrations must follow to comply with online transparency obligations. The schemes, provided for by the transparency decree (Legislative Decree No. 33/2013), take into account the various observations made by the Office. To ensure the confidentiality of the interested parties and avoid the risk of potential sanctions for violations of privacy regulations, public administrations must limit themselves, among other things, to publishing only necessary data in the "transparent administration" section of their respective websites, such as, for example, the phone number, the email address, and the certified email address of the office - and not the employee's data - to whom the citizen can turn for requests to the administration. And in the results of public competitions, they must publish the name, surname, (date of birth, in case of homonymy) and the ranking position of the winners and those deemed suitable declared winners following the ranking progression. Furthermore, in the publication of data concerning payments, public administrations must obscure the identifying data of the recipients of economic benefits below one thousand euros in the calendar year and in any case if the publication could provide information related to health status or socio-economic hardship. In giving its favorable opinion on the standard publication schemes, the Authority, however, requested Anac to raise the level of protection. For example, in the case of publishing data related to performance evaluation and the distribution of bonuses to staff, public administrations must avoid publishing overly detailed data that could identify the employee and the amount of the bonus granted (or not granted) in their favor. They may instead publish data referring to the total amount of bonuses allocated and the amount of bonuses actually distributed. The Authority also invites to consider the opportunity to provide for a transitional period to allow public administrations to progressively and gradually adapt to the new publication methods on institutional websites.

****Intercepts of the European Prosecutor's Office: approval of the Privacy Authority for the national database****

Approval from the Privacy Authority for the decree establishing the national archive of minutes and recordings of interceptions ordered by the European Prosecutor's Office (EPPO - European Public Prosecutor's Office) through stations identified in some national Prosecutor's Offices. However, the Authority has requested that further technological measures be adopted to protect the data.

The EPPO is an independent institution of the European Union, operational since June 1, 2021, based in Luxembourg, competent to investigate and prosecute crimes that harm the financial interests of the EU. The draft decree from the Minister of Justice, examined by the Authority, regulates the methods of storage and consultation of the data contained in the archive and the subjects authorized to access it through the stations established at the service locations of the delegated European Prosecutors. Thus, access to the national archive will be granted to the judge proceeding and their assistants; the public prosecutor and their assistants, including the judicial police officers delegated to the listening; the defenders of the assisted parties, if necessary, with the assistance of an interpreter. The national archive, kept under the exclusive direction and supervision of the European Prosecutor or, in the cases provided for, of the delegated European Prosecutor, will retain the full version of all minutes and all recordings of the interceptions carried out in the proceedings in which the European Prosecutor's Office has exercised its competence, as well as any other related acts. In issuing a favorable opinion on the draft decree, the Authority considered that it does not present particular criticalities from the

perspective of data protection, but nevertheless requested - in analogy with national systems - that it be provided, regarding information flows and data storage, for the use of cryptographic techniques, utilizing secure network protocols and robust encryption algorithms, also taking into account any recommendations provided by the National Cybersecurity Agency. The Authority also requested the adoption of multi-factor authentication procedures, with credentials and authentication devices assigned to the user and preferably managed directly by the Ministry of Justice. Finally, the draft decree must contain measures aimed at ensuring the

****Operational Continuity and Disaster Recovery****

(recovery of systems), as well as detecting, through specific alerts, anomalous or at-risk behaviors, providing for the tracking of operations performed and audits at least annually.

****THE ACTIVITIES OF THE GUARANTOR - FOR THOSE WHO WANT TO KNOW MORE****

The most important interventions and measures recently adopted by the Authority

The first stop of the "Privacy Tour 2024" starts from Messina. The event organized to promote the themes of data protection and the conscious use of technologies – Press Release of April 9, 2024
Cryptocurrencies: regarding the exchange of data, the Privacy Guarantor warns Worldcoin - Press Release of April 2, 2024

Project ARC II: on April 9 in Rome, an International Conference on privacy dedicated to SMEs – Press Release of March 29, 2024

****NEWSLETTER of the Guarantor for the protection of personal data****

(Registered at the Court of Rome no. 654 of November 28, 2002).

Responsible Director: Baldo Meo.

Direction and editorial office: Guarantor for the protection of personal data, Piazza Venezia, n. 11 - 00187 Rome.

Tel: 06.69677.2751 - Fax: 06.69677.3785

The newsletter is available on the website www.gpdp.it